

RedScope

AI-Assisted Penetration Test on a Vulnerable Lab

Detailed project walkthrough for a four-person team

Project at a glance

This project combines authorized penetration testing, evidence collection, ATT&CK; mapping, report writing, and a small adversarial-ML experiment.

The lab contains DVWA, OWASP Juice Shop, and a Metasploitable-like Linux VM, all isolated inside the project workspace.

The final story is simple: prove the attack chain, explain the impact, and show why the ML detector can be evaded and then improved.

What	Why	Who
A controlled lab pentest with one web exploit, one network exploit, post-exploitation, and an ML evasion experiment.	To demonstrate how real attack chains work, why scope and evidence matter, and where simple detectors fail.	Shamanth R Singh, Ajith Mohan, Saiteja Kacham, and Madhurjya Deka.

Read this PDF in order

Start with the overview to understand the project in plain language.

Then follow the lab architecture and the phase-by-phase walkthrough.

Finish with the deliverables, safety rules, and evidence map.

What This Project Is

RedScope is an authorized capstone exercise built around a deliberately vulnerable lab. The lab is not a real target. It is a controlled environment used to demonstrate the full attack lifecycle from planning through reporting.

The workspace combines web application security testing, network/service exploitation, post-exploitation enumeration, and a small adversarial-ML experiment. Those pieces are linked together so the final report reads like a real red-team engagement, not a scattered set of tool outputs.

- DVWA is used to teach classic web attacks such as SQL injection and other input handling mistakes.
- OWASP Juice Shop represents a more modern application with APIs, access control issues, and exposed routes.
- Metasploitable provides a vulnerable Linux service stack for network enumeration and foothold practice.
- The ML section is intentionally small and educational. It shows how a detector can be trained, fooled, and then improved.

Why It Exists

The point of the capstone is not to brag about breaking things. The point is to prove that an assessment can be disciplined, repeatable, and useful to a client or instructor.

A good engagement answers four questions: what is exposed, how an attacker could get in, how far the attacker could go, and what should be fixed first.

This project also forces responsible use of AI. Commands suggested by an assistant are reviewed before execution, evidence is written down, and the report explains what was verified rather than what was assumed.

- Show a full attack chain inside a safe lab.

- Demonstrate evidence collection and ATT&CK; mapping.
- Explain the business impact in human terms.
- Show how a toy ML detector can be evaded and then improved.

Who Is Involved

The team consists of four members: Shamanth R Singh, Ajith Mohan, Saiteja Kacham, and Madhurjya Deka. The final deliverables are written in a team format, so the reports and debrief need to read as one coordinated engagement.

The project files treat the team as a shared operator group. The exact internal division of labor can be adjusted by the team, but the final outputs should stay consistent: one story, one evidence trail, one set of findings, and one debrief.

- The executive audience wants a short explanation of impact and priority.
- The technical audience wants evidence, ATT&CK; tags, and reproduction steps.
- The debrief audience wants a clear narrative from recon to remediation.

How The Lab Works

The environment is split into a Windows host, a Kali attacker VM, two Docker-based web apps, and one isolated Metasploitable VM. The lab uses a VirtualBox NAT network so the vulnerable VM is not bridged to the physical LAN.

From the Windows host, the two web apps are available at localhost ports 3000 and 8080. From Kali, the web apps are reached through the Windows host IP, while the Metasploitable VM lives directly on the isolated lab subnet.

Component	Role	Key detail
Windows host	Runs Docker targets	localhost:3000 and localhost:8080
Kali VM	Attacker workstation	10.77.0.4 on the lab network
DVWA	Classic web target	Low-security lab mode
Juice Shop	Modern web target	API and route exposure
Metasploitable	Network target	10.77.0.3 with legacy services

Project Workflow

The workflow follows a standard pentest shape: plan, recon, scan, assess, exploit, enumerate, document, model, evade, and report. That order matters because the later steps depend on evidence from the earlier steps.

Phase	What happens	Why it matters
Planning	Write the RoE, define scope, and confirm the team and safety rules.	Prevents scope creep and keeps the work inside the authorized lab.
Reconnaissance	Discover hosts, services, versions, web routes, and obvious attack surfaces.	Builds the inventory that drives the rest of the assessment.

Scanning	Use tools like Nmap, Gobuster, WhatWeb, Burp, and exploit helpers.	Turns passive information into reproducible evidence.
Web exploitation	Exploit DVWA SQL injection and the Juice Shop FTP listing exposure.	Demonstrates application-level compromise and information disclosure.
Network exploitation	Use the exposed Metasploitable bind shell to gain root command execution.	Shows a clean foothold on a vulnerable service with no authentication.
Post-exploitation	Enumerate the host and record identity, IP, and privilege level.	Proves the impact and supports ATT&CK; mapping.
ML defender	Train a toy classifier and compare a baseline with a second defender.	Shows how feature choice changes false negatives and false positives.
Reporting	Write the executive report, technical report, and debrief.	Turns raw attack evidence into something a reviewer can judge.

What Actually Happened

The first web exploit was DVWA SQL injection. The database was reset to the documented default state, the default credentials were used, and the vulnerable endpoint returned multiple user records when the injected query was submitted.

The second web exploit was the Juice Shop `/ftp` route. It exposed a browsable directory listing and directly revealed files that looked internal, including `legal.md` and backup material.

The network exploit used the Metasploitable bind shell on TCP 1524. The shell returned a root prompt with no authentication, which is why it is the highest-risk finding in the lab.

The post-exploit step recorded the host identity and network placement, which is the minimum useful proof once a foothold exists.

The ML phase trained a small word-token detector, then compared it with a second character n-gram defender. The second model reduced the original evasion success, but it also introduced a false positive on the tiny dataset. That is the correct trade-off to explain in the report.

Why the attack chain matters

A single weak web endpoint can leak data.

A single exposed service can yield root command execution.

A tiny ML model can be fooled or overfit.

The value of the project is showing the chain end to end, not just one isolated issue.

Deliverables And Rubric

The team version of the capstone expands the deliverables beyond the individual scope. The final package should look like a real engagement: signed authorization, attack narrative, proof-of-concepts, ML write-up, executive report, technical report, and a debrief presentation.

Deliverable	Team target	Status in this workspace
Signed RoE	Required before Week 2	Complete
Attack timeline with ATT&CK; tags	Required	Complete

Two reproducible web PoCs	Team scope	Complete
One reproducible network PoC	Team scope	Complete
Adversarial-ML evasion write-up	Required	Complete
Second defender comparison	Optional stretch goal	Complete
Executive report	6-7 pages for team mode	Complete
Technical report	18-22 pages for team mode	Complete
Red-team debrief	Required presentation format	Drafted

Key Results

The findings register now contains one critical issue, three high issues, and six medium issues. Three findings are validated through exploit evidence: the Metasploitable bind shell, DVWA SQL injection, and the Juice Shop FTP listing exposure.

The ML side has two useful stories. First, a baseline detector missed a URL-encoded XSS-style sample. Second, a character n-gram defender improved that weak point but did not produce a perfect model. That balance is exactly what the capstone wants you to discuss honestly.

ID	Finding	Severity	Status
F-006	Metasploitable bind shell service exposed	Critical	Exploited
F-008	DVWA running in low-security lab mode	High	Exploited
F-010	Juice Shop FTP directory listing exposes confidential files	Medium	Exploited

Safety And Ethics

All offensive activity stays inside the lab. No public targets are used, no real data is exfiltrated, and no denial-of-service activity is performed.

Any AI-generated suggestion is reviewed before execution. If a command or interpretation is accepted, the report should make that verification clear.

All evidence should stay inside the project workspace. Sensitive or real-world data does not belong in the lab or in the LLM prompt history.

- Keep the RoE signed and visible.
- Record commands and results.
- Describe what was verified, not what was guessed.
- Stop when the scope stops being clear.

Evidence Map

The project already contains the important artifacts. The PDF should not replace them. It should explain how they fit together.

Artifact	File
----------	------

Signed RoE	01-planning\rules-of-engagement.md
Recon report	02-recon\week1-recon-report.md
DVWA SQLi PoC	03-evidence\web\dvwa-sqli-poc.md
Juice Shop FTP listing PoC	03-evidence\web\juice-shop-ftp-directory-listing.md
Metasploitable bind shell PoC	03-evidence\network\metasploitable-bind-shell-root.md
Post-exploit enum	03-evidence\post-exploitation\metasploitable-root-enum.md
ML baseline	03-evidence\ml\detector-run-2026-06-28.md
ML defender comparison	03-evidence\ml\defender-comparison-2026-06-28.md
Executive report	06-reports\executive-report.md
Technical report	06-reports\technical-report.md
Debrief	07-presentation\debrief.md

How To Present It

The debrief should follow the same sequence as the report: scope, architecture, recon, web exploit, network exploit, post-exploit, ML result, business impact, and remediation.

Each speaker should be able to explain the same chain without overloading the audience with terminal noise. The job of the presentation is to make the evidence legible.

Closing Summary

If someone reads only this PDF, they should understand the project without opening the rest of the workspace. RedScope is a controlled lab penetration test with an explicit safety boundary, a complete attack narrative, and a small adversarial-ML experiment that proves a simple detector is not enough on its own.

The right takeaway is practical: use disciplined scope, keep evidence clean, explain business impact plainly, and test defenses against realistic variations rather than trusting a single model or a single assumption.